

บทที่ 5

การปรับค่าพารามิเตอร์ของระบบและผลการทดลอง

5.1 การปรับค่าพารามิเตอร์ของระบบ

จากที่ได้กล่าวมาแล้วในบทที่ 3 ว่าในอัลกอริทึมวัดค่าพฤติกรรมการใช้งานนั้นมีตัวแปรที่สำคัญอยู่ 4 ตัวแปรคือ

1. จำนวนสมาชิกใน Seq แต่ละ Seq
2. จำนวนข้อมูลที่ใช้เปรียบเทียบจากฐานข้อมูลการใช้งานในช่วงระยะเวลาปัจจุบัน
3. จำนวนข้อมูลที่ใช้เปรียบเทียบจากฐานข้อมูลการใช้งานในช่วงระยะเวลาที่ผ่านมา
4. ค่าต่ำสุดที่ยอมรับได้ของการเปลี่ยนแปลงพฤติกรรม

ภาพรวมของการปรับพารามิเตอร์ทั้ง 4 ตัวคือ การหาพารามิเตอร์ 3 ค่าแรกนั้นต้องทำการทดลองและเปรียบเทียบค่าเพื่อหาค่าที่เหมาะสมแล้วจึงใช้ค่าที่ได้ทั้ง 3 ไปช่วยหาค่าตัวแปรตัวที่ 4 ต่อไป

5.1.1 การทดลองหาค่าพารามิเตอร์ 3 ค่าแรกที่เหมาะสม

กำหนดตัวแปร

- ให้ SEQ_LEN แทนจำนวนสมาชิกใน Seq แต่ละ Seq
- ให้ R_WINDOW_SIZE แทนจำนวนข้อมูลที่ใช้เปรียบเทียบจากฐานข้อมูลการใช้งานในช่วงระยะเวลาปัจจุบันให้
- ให้ DB_WINDOW_SIZE แทนจำนวนข้อมูลที่ใช้เปรียบเทียบจากฐานข้อมูลการใช้งานในช่วงระยะเวลาที่ผ่านมา

ในการทดลองนี้ใช้ผู้ใช้งาน 3 คนเป็นตัวอย่างทดสอบโดย

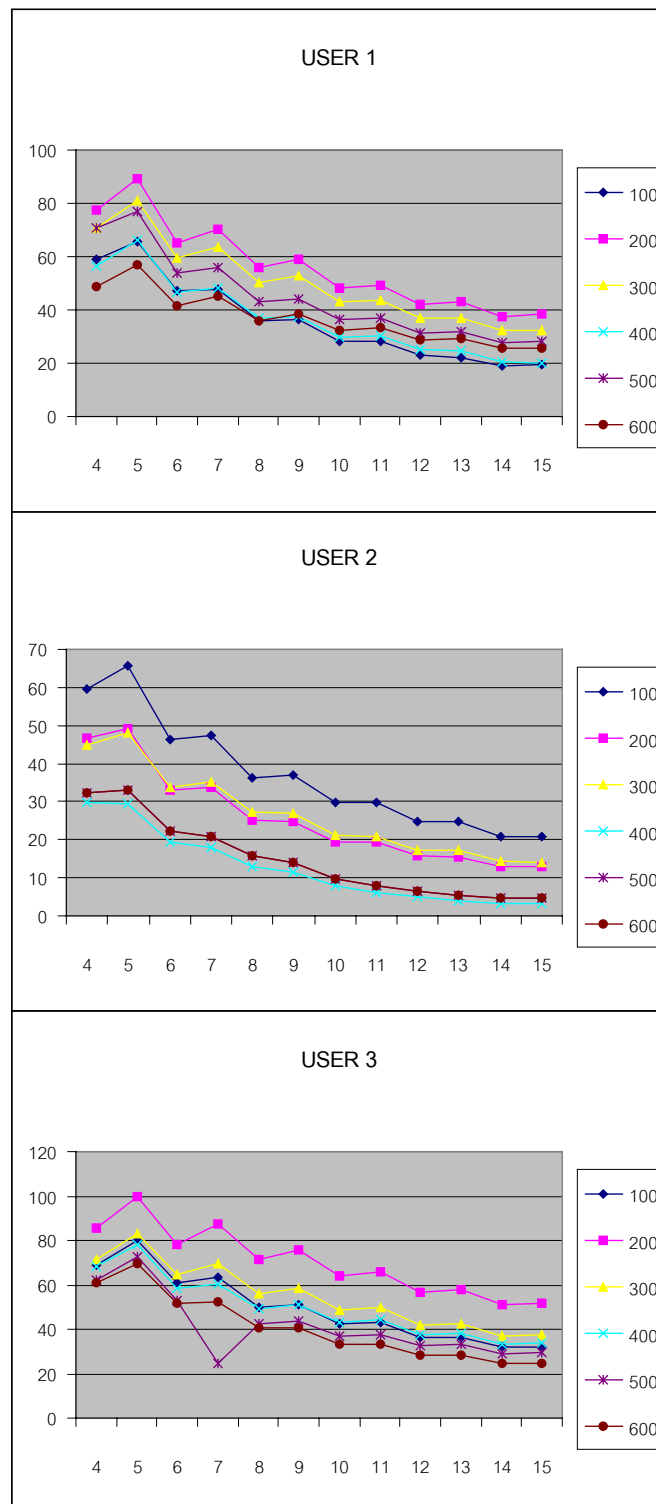
- ผู้ใช้คนที่ 1 มีจำนวนข้อมูลทั้งหมด 10580 เรคอร์ด
- ผู้ใช้คนที่ 2 มีจำนวนข้อมูลทั้งหมด 709 เรคอร์ด
- ผู้ใช้คนที่ 3 มีจำนวนข้อมูลทั้งหมด 14580 เรคอร์ด

โดยในผู้ใช้แต่ละคนจะทำการเปรียบเทียบข้อมูลดังนี้

1. SEQ_LEN ที่ค่าระหว่าง 4 ถึง 15
2. R_WINDOW_SIZE ที่ค่า 100, 200, 300, 400, 500, 600
3. DB_WINDOW_SIZE ที่ค่า 100, 200, 400, 700

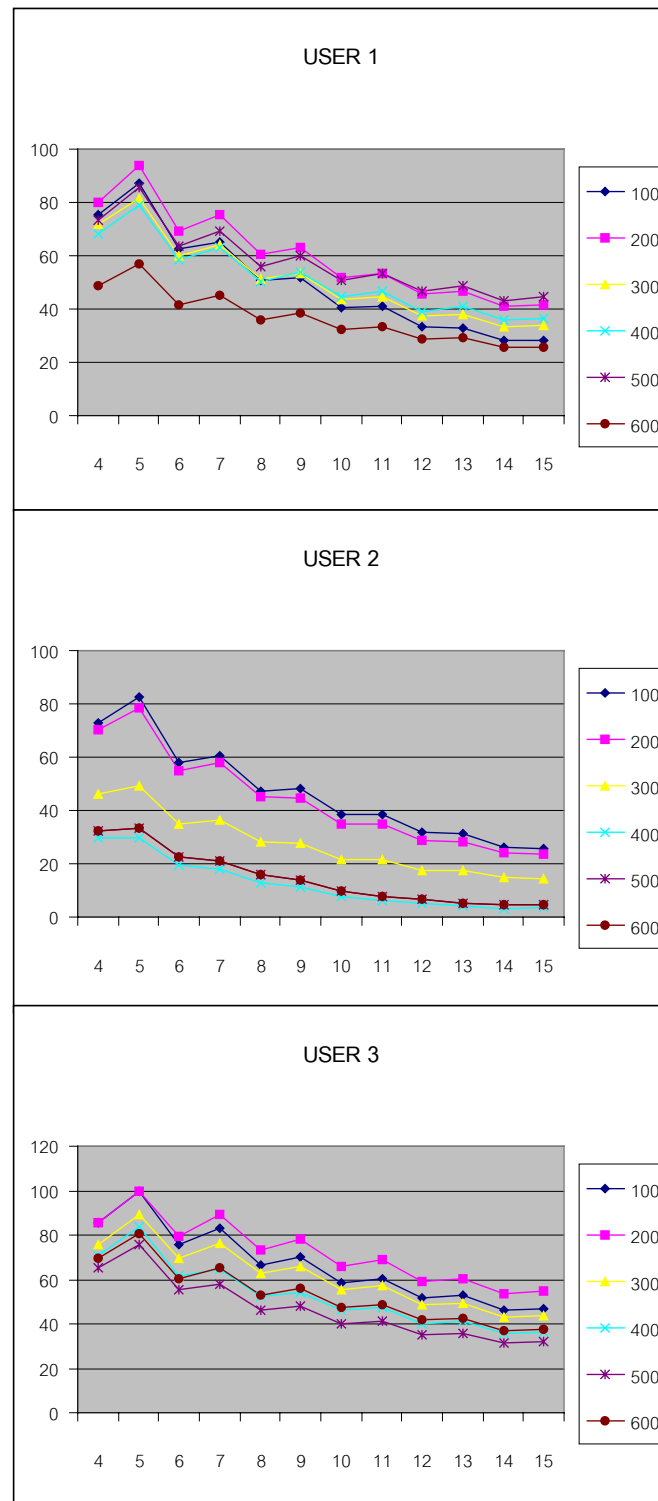
โดยในแต่ละกราฟผลการทดลองนั้นแกนนอน(x) หมายถึงค่า SEQ_LEN แกนตั้ง(y) หมายถึงค่าความเหมือนของพฤติกรรม ชุดข้อมูลแต่ละชุดในกราฟนั้นๆ จะเป็นการเปรียบเทียบค่า R_WINDOW_SIZE ตามที่กำหนดไว้ข้างต้น และในกราฟหนึ่งๆ จะมีค่า DB_WINDOW_SIZE คงที่

การทดลองครั้งที่ 1 ค่า DB_WINDOW_SIZE = 100



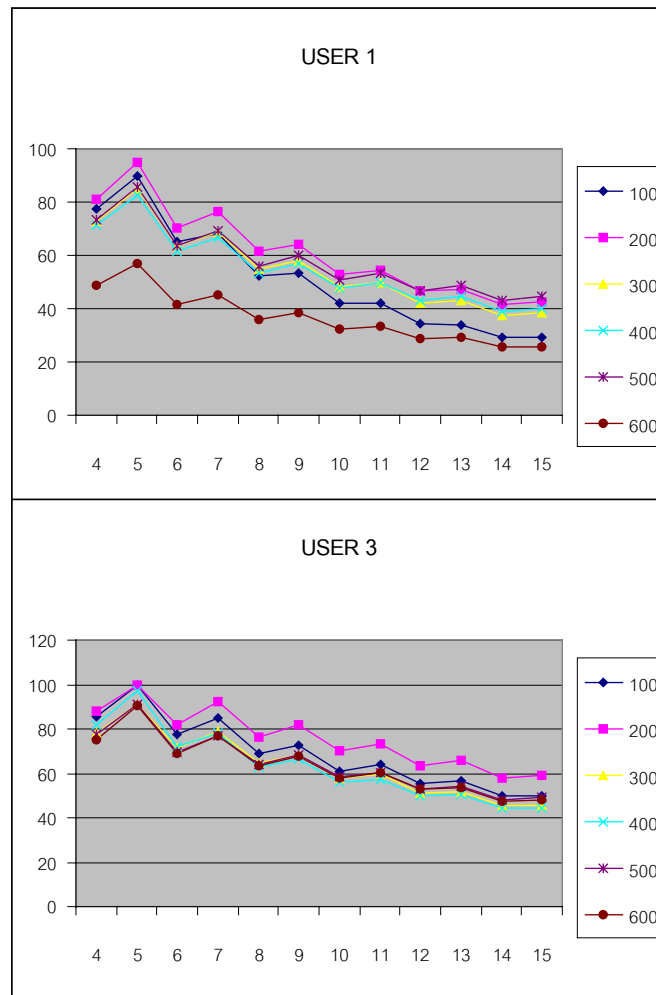
รูปที่ 5.1 การทดลองหาค่าพารามิเตอร์โดยให้ค่า DB_WINDOW_SIZE=100

การทดลองครั้งที่ 2 ค่า DB_WINDOW_SIZE = 200



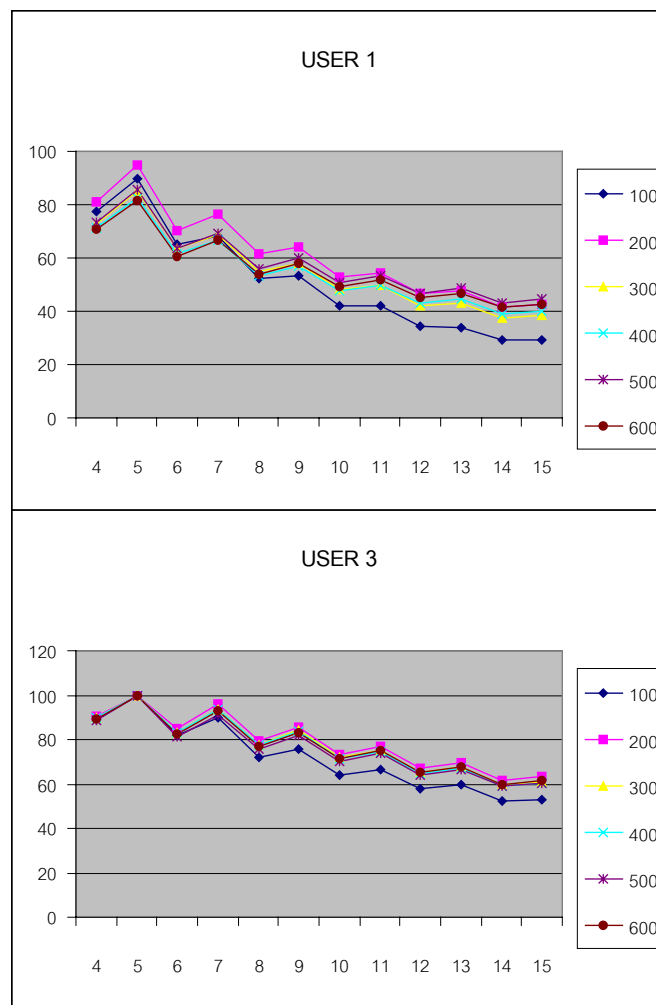
รูปที่ 5.2 การทดลองหาค่าพารามิเตอร์โดยให้ค่า DB_WINDOW_SIZE=200

การทดลองครั้งที่ 3 ค่า DB_WINDOW_SIZE = 400



รูปที่ 5.3 การทดลองหาค่าพารามิเตอร์โดยให้ค่า DB_WINDOW_SIZE=400

การทดลองครั้งที่ 4 ค่า DB_WINDOW_SIZE = 700



รูปที่ 5.4 การทดลองหาค่าพารามิเตอร์โดยให้ค่า DB_WINDOW_SIZE=700

สรุปและอธิบายผลการทดลอง

จากกราฟการทดลองทั้งหมดเราเลือกค่าตัวแปรทั้ง 3 ตัวได้ดังนี้

1. ค่า SEQ_LEN เลือกค่า 9

เหตุผล สังเกตจากกราฟจะเห็นว่ายิ่งค่า SEQ_LEN มีค่าน้อย ผลลัพธ์ก็จะยิ่งมีค่าความเหมือนมากเนื่องมาจากถ้า SEQ_LEN น้อยๆ จะทำให้จำนวนคำสั่งที่นำมาเทียบในแต่ละครั้งนั้นมีจำนวนน้อยดังตัวอย่างข้างล่างนี้

ข้อมูล: "ls", "-color", "-la", "<f>", "vi", "<f>", "cc", "<f>", "-o", "<f>"

กรณี SEQ_LEN=4 จะได้ Seq={ "ls", "-color", "-la", "<f>" }

กรณี SEQ_LEN=9 จะได้ Seq={ "ls", "-color", "-la", "<f>", "vi", "<f>", "cc", "<f>", "-o" }

ถ้าค่า SEQ_LEN ยิ่งมีค่าน้อยหมายความว่าในการเทียบลำดับข้อมูลในแต่ละครั้งจะเป็นการเทียบการใช้งานเพียงคำสั่งเดียว ซึ่งไม่ตรงกับจุดประสงค์ที่ต้องการเพราะเราต้องการวัดค่าลำดับการใช้งานคำสั่งด้วยจึงต้องเทียบกันหลายๆ คำสั่งในครั้งหนึ่งๆ เราจึงไม่เลือกค่า SEQ_LEN น้อยๆ มาใช้งาน

2. ค่า R_WINDOW_SIZE เลือกค่า 200

เห็นได้อย่างชัดเจนว่าส่วนใหญ่ของกราฟผลลัพธ์ค่า R_WINDOW_SIZE มีค่า 200 ให้ผลลัพธ์ค่าความเหมือนที่สูงกว่าค่าอื่น ๆ

3. ค่า DB_WINDOW_SIZE เลือกค่า 400

ค่า DB_WINDOW_SIZE ที่น้อยกว่านี้ให้ค่าความเหมือนที่ต่ำเกินไป และค่าที่สูงกว่านี้ให้ค่าความเหมือนที่ใกล้เคียงกัน ดังนั้นจึงเลือกค่า 400 เพราะจะใช้เวลาในการวิเคราะห์น้อยกว่า ใช้เวลาในการเก็บฐานข้อมูลการวิเคราะห์น้อยกว่า

หมายเหตุ หากพิจารณาการทดลองที่มีค่า DB_WINDOW_SIZE=200 ของผู้ใช้คนที่ 2 จะเห็นว่ากราฟค่าความเหมือนมีค่าต่ำลงเรื่อยๆ เห็นได้ชัด มีสาเหตุมาจากจำนวนข้อมูลฐานข้อมูลไม่เพียงพอ เพราะเป็นผู้ใช้ใหม่ ดังนั้นการทดลองถัดไปจึงไม่ได้นำผู้ใช้คนที่ 2 เข้ามาทดลองด้วย

5.1.2 การหาค่าต่ำสุดที่ยอมรับได้ของการเปลี่ยนแปลงพฤติกรรม

จากการทดลองที่ผ่านมาเราได้ค่าพารามิเตอร์ที่ใช้ในการวิเคราะห์ครบแล้วทั้ง 3 ค่า ซึ่งจะนำมาใช้ในการหาค่าพารามิเตอร์ต่ำสุดที่ยอมรับได้ของการเปลี่ยนแปลงพฤติกรรมโดยมีวิธีการทดลองดังนี้

- ใช้ข้อมูลพฤติกรรมของผู้ใช้ 3 คนในการทดลอง
- ทดลองพฤติกรรมที่ทำให้เกิดการบุกรุกขึ้นโดยนำฐานข้อมูลการใช้งานในช่วงระยะเวลาปัจจุบันของแต่ละคน(R_DATA) มาเทียบกับฐานข้อมูลการใช้งานในช่วงระยะเวลาที่ผ่านมา(DB_DATA) ของทุกคน เสมือนกับว่าผู้ใช้คนหนึ่งถูกผู้ใช้คนอื่นนำแอคเคาท์ของตนมาใช้งานแล้วหาค่าความเหมือนของพฤติกรรม

- บันทึกและวิเคราะห์ผลการทดลอง

ซึ่งจากการทดลองได้ผลลัพธ์ดังนี้

DB_DATA \ R_DATA	ผู้ใช้งานคนที่ 1	ผู้ใช้งานคนที่ 2	ผู้ใช้งานคนที่ 3
ผู้ใช้งานคนที่ 1	60.02	35.59	14.81
ผู้ใช้งานคนที่ 2	22.22	58.50	14.41
ผู้ใช้งานคนที่ 3	16.79	21.58	62.09

ตารางที่ 5.1 ผลการทดลองการเปรียบเทียบพฤติกรรม

สรุปผลการทดลอง

สังเกตว่าในระบบนี้ค่าพฤติกรรมของผู้ใช้ค่อนข้างไม่คงที่ โดยค่าความเหมือนพฤติกรรมของตัวผู้ใช้งานเองจะอยู่ที่ประมาณ 60 และค่าความเหมือนของพฤติกรรมเมื่อเทียบกับผู้ใช้นั้นๆ จะอยู่ที่ 35 ลงมา แสดงว่าช่วงค่าข้อมูลที่เราจะเลือกไปใช้เป็นค่าต่ำสุดที่ยอมรับได้ของการเปลี่ยนแปลงพฤติกรรมน่าจะอยู่ระหว่าง 35-59 โดยในที่นี้จะยึดค่า 40 เป็นค่าที่ใช้ในการทดสอบระบบต่อไป

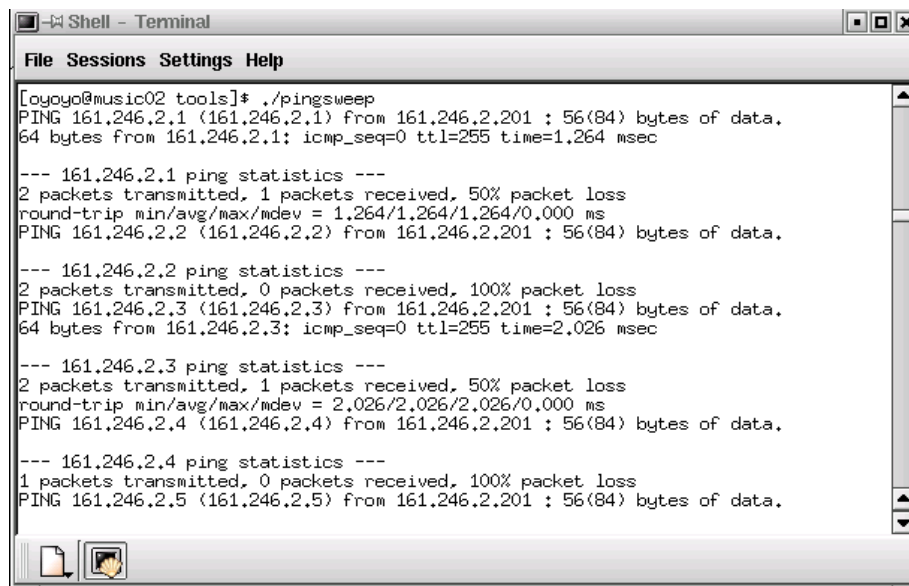
5.2 ทดสอบบุกรุกโดยให้มีพฤติกรรมการใช้งานที่ผิดปกติของผู้ใช้

ในหัวข้อนี้เป็นการทดสอบการใช้งานที่ผิดปกติไปเพื่อทดสอบระบบตรวจจับผู้บุกรุก

Ping sweeps

เป็นหนึ่งในพื้นฐานการบุกรุกที่นิยมกระทำกัน ก็คือ การ ping ไปยังเครื่องเป้าหมายจำนวนมากพร้อม ๆ กัน ในลักษณะคล้ายกับการกวาดหรือกราดยิง ซึ่งเรียกว่าเป็นการทำ ping sweep เพื่อตรวจสอบว่าเครื่องปลายทางใดบ้างที่ยังเปิดทำงานอยู่ซึ่งจะได้ข้อมูลของระบบ โดยปกติ ถ้าใช้คำสั่ง ping ธรรมดา, ping จะมีการส่งแพ็กเก็ต ICMP ECHO (Type 8) ออกไปยังเครื่องปลายทางและรอคอย ICMP ECHO_REPLY (Type 0) ที่ถูกส่งกลับมา

จากรูปที่ 5.5 สังเกตว่าจากการทำงานของ ping sweeps จะทำการ ping ไปยังเครื่องเป้าหมายตั้งแต่ IP หมายเลข 161.246.2.1 จนถึง IP หมายเลข 161.246.2.120 เพื่อสำรวจว่ามีเครื่องใดเปิดให้บริการอยู่บ้างเพื่อเป็นแนวทางในการติดต่อกับเครื่องนั้น ๆ เพื่อทำการบุกรุกต่อไป



```

[oyoyo@music02 tools]$ ./pingsweep
PING 161.246.2.1 (161.246.2.1) from 161.246.2.201 : 56(84) bytes of data.
64 bytes from 161.246.2.1: icmp_seq=0 ttl=255 time=1.264 msec

--- 161.246.2.1 ping statistics ---
2 packets transmitted, 1 packets received, 50% packet loss
round-trip min/avg/max/mdev = 1.264/1.264/1.264/0.000 ms
PING 161.246.2.2 (161.246.2.2) from 161.246.2.201 : 56(84) bytes of data.

--- 161.246.2.2 ping statistics ---
2 packets transmitted, 0 packets received, 100% packet loss
PING 161.246.2.3 (161.246.2.3) from 161.246.2.201 : 56(84) bytes of data.
64 bytes from 161.246.2.3: icmp_seq=0 ttl=255 time=2.026 msec

--- 161.246.2.3 ping statistics ---
2 packets transmitted, 1 packets received, 50% packet loss
round-trip min/avg/max/mdev = 2.026/2.026/2.026/0.000 ms
PING 161.246.2.4 (161.246.2.4) from 161.246.2.201 : 56(84) bytes of data.

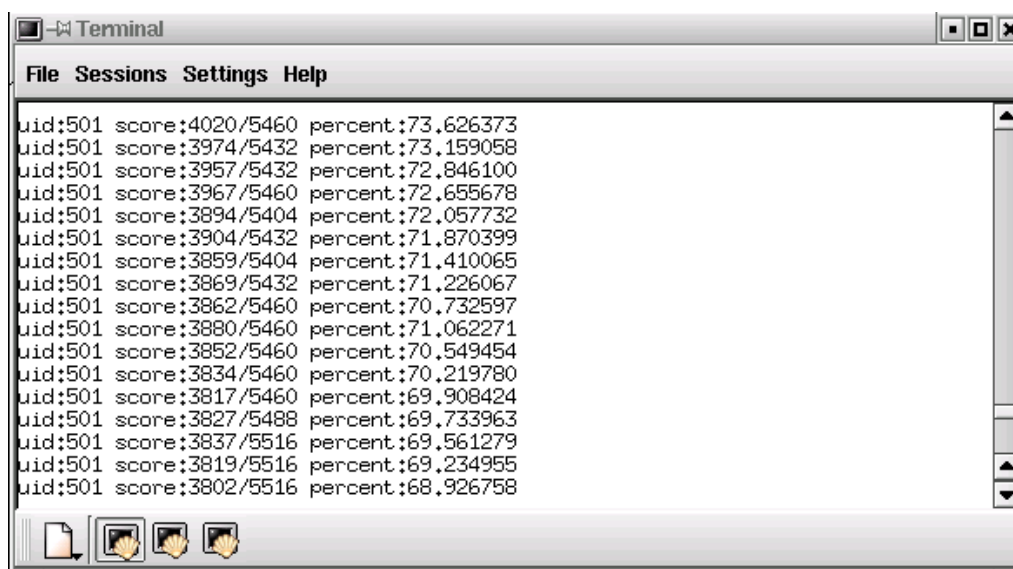
--- 161.246.2.4 ping statistics ---
1 packets transmitted, 0 packets received, 100% packet loss
PING 161.246.2.5 (161.246.2.5) from 161.246.2.201 : 56(84) bytes of data.

```

รูปที่ 5.5 แสดงผลของการทำงาน ping sweeps

การทดลอง

จากการทดลองโดยให้ผู้ใช้ทำการ ping sweeps ไปยังเครื่องเป้าหมาย โดยระบบตรวจจับผู้บุกรุกคอมพิวเตอร์สามารถรายงานความเปลี่ยนแปลงที่เกิดขึ้นจากการใช้คำสั่ง ping ดังรูปข้างล่างนี้



```

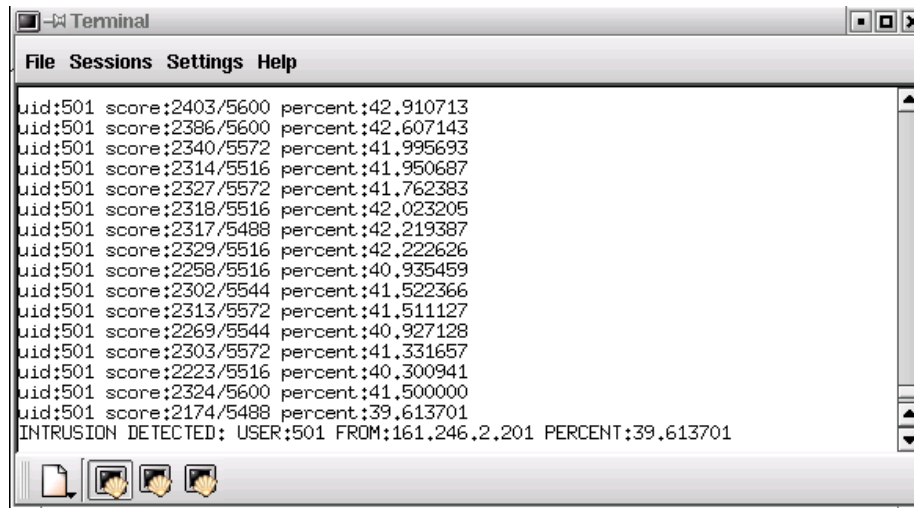
uid:501 score:4020/5460 percent:73.626373
uid:501 score:3974/5432 percent:73.159058
uid:501 score:3957/5432 percent:72.846100
uid:501 score:3967/5460 percent:72.655678
uid:501 score:3894/5404 percent:72.057732
uid:501 score:3904/5432 percent:71.870399
uid:501 score:3859/5404 percent:71.410065
uid:501 score:3869/5432 percent:71.226067
uid:501 score:3862/5460 percent:70.732597
uid:501 score:3880/5460 percent:71.062271
uid:501 score:3852/5460 percent:70.549454
uid:501 score:3834/5460 percent:70.219780
uid:501 score:3817/5460 percent:69.908424
uid:501 score:3827/5488 percent:69.733963
uid:501 score:3837/5516 percent:69.561279
uid:501 score:3819/5516 percent:69.234955
uid:501 score:3802/5516 percent:68.926758

```

รูปที่ 5.6 แสดงผลการทำงานของ IDS โฮสต์

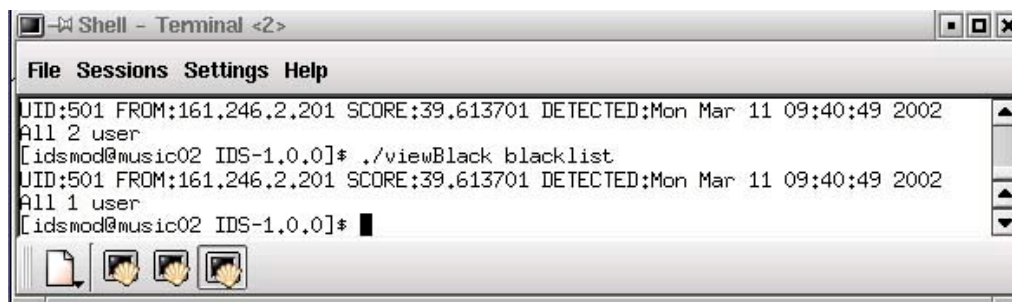
จากรูปที่ 5.6 เป็นผลการทำงานของ IDS โฮสต์ โดยแสดงหมายเลขประจำตัวของผู้ใช้งาน (User ID) ที่ใช้คำสั่ง ping และมีค่าของเปอร์เซ็นต์โดยเปรียบเทียบค่าความเหมือนของคำสั่ง หากคำสั่งมีความ

เหมือนกับการใช้งานในช่วงระยะที่ผ่านมามากจะมีค่าสูง แต่หากมีความเหมือนกับการใช้งานในช่วงระยะผ่านมาน้อยจะมีค่า ซึ่งสังเกตว่ามีผู้ใช้ที่มีค่า UID = 501 ใช้คำสั่ง ping ติดต่อกันเป็นจำนวนมากทำให้ค่าความเหมือนของการใช้งานลดลงเรื่อย ๆ



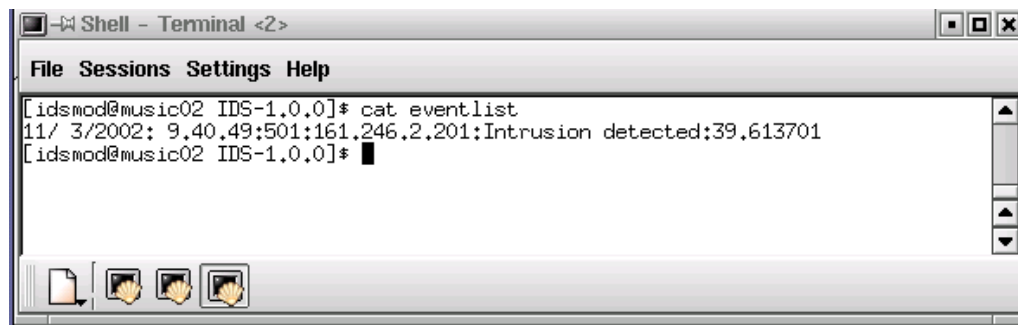
รูปที่ 5.7 แสดงผลการทำงานของ IDS โฮสต์ เมื่อตรวจพบการบุกรุก

จากรูปที่ 5.7 เมื่อผู้ใช้มีความเหมือนต่ำกว่าค่าที่ตั้งไว้ (ในที่นี้ตั้งค่าไว้ที่ 40) IDS โฮสต์ ก็ทำการตอบสนองจากการวิเคราะห์ว่ามีการบุกรุกเกิดขึ้นให้แก่ผู้ดูแลระบบได้ทำการติดตามต่อไป



รูปที่ 5.8 บันทึกข้อมูลการบุกรุกลงไฟล์ blacklist

จากรูปที่ 5.8 จะบันทึกข้อมูลต่าง ๆ ของผู้บุกรุกไว้ในไฟล์ที่ชื่อ blacklist โดยในไฟล์นี้จะบันทึกข้อมูลแบบลักษณะของไดนามิก คือ ปรับเปลี่ยนขนาดได้เมื่อมีผู้บุกรุกเพิ่มขึ้นหรือลดลง ข้อมูลที่ทำการบันทึก เช่น หมายเลขประจำตัวผู้ใช้ หมายเลขไอพี (IP Address) ค่าของความเหมือน วัน เดือน ปี และเวลาที่เกิดการบุกรุก เพื่อใช้ในการตรวจสอบในภายหลังว่าเมื่อมีการติดต่อจากผู้ใช้ให้ติดตามพฤติกรรมการใช้งานว่ามีพฤติกรรมที่เป็นปรกติมากขึ้นหรือไม่ หากมีพฤติกรรมที่เป็นพฤติกรรมปรกติมากขึ้นก็ทำการลบรายชื่อออกจากไฟล์ blacklist



รูปที่ 5.9 แสดงไฟล์ eventlist

จากรูปที่ 5.9 แสดงไฟล์ eventlist ที่เก็บรวบรวมข้อมูลทั้งหมดเป็นล็อกไฟล์ คือ เมื่อเกิดเหตุการณ์การบุกรุกขึ้น ระบบตรวจจับผู้บุกรุกคอมพิวเตอร์จะทำการบันทึกประวัติการบุกรุกทั้งหมดไว้ในไฟล์นี้ โดยแตกต่างจากไฟล์ blacklist คือ เมื่อผู้บุกรุกมีพฤติกรรมการใช้งานที่ดีขึ้นแล้ว ระบบจะทำการลบรายชื่อผู้ใช้งานนั้นออก แต่ในไฟล์ eventlist ยังคงเก็บไว้อยู่ เพื่อมีไว้ให้ผู้ดูแลระบบจะทำการตรวจสอบในภายหลังได้